

AN TOÀN THÔNG TIN (INSE330380)

CHƯƠNG VII TỔNG QUAN VỀ MÃ HÓA (Cryptography)

Ths. ĐỖ MINH HẬU

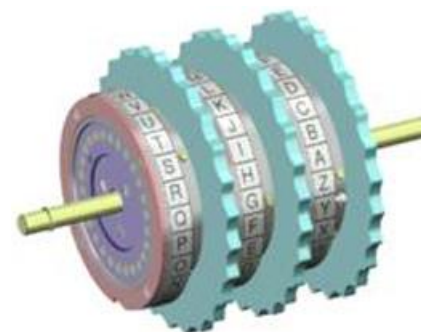
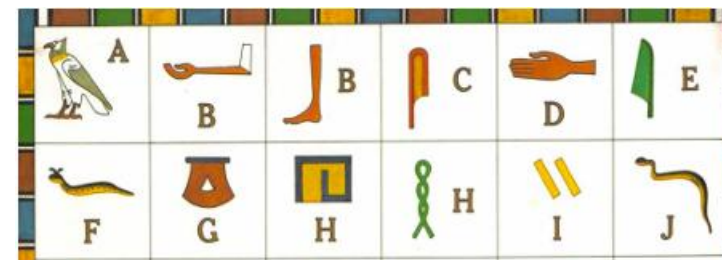
- ☐ Giới thiệu bài học
- ☐ Cơ bản về Mật mã
- ☐ Dịch vụ mật mã. Nguyên thủy mật mã (cryptographic primitives)
- ☐ Các kỹ thuật mật mã: Substitution và Transposition
- ☐ Các dạng mật mã: Symmetric và asymmetric encryption
- ☐ Mã hóa Hash
- ☐ Digital signatures
- ☐ Tóm tắt

- ☐ Một trong các tiêu chí về an toàn thông tin là cần đảm bảo tính bí mật (confidentiality)
- ☐ Giải pháp để đảm bảo tiêu chí bí mật là Mật mã
- ☐ Nhiều ứng dụng hiện tại đã sử dụng Mật mã để đảm bảo tính bí mật của thông tin
- ☐ Vậy các kỹ thuật Mật mã là gì? các thuật toán Mật mã gồm mã hóa và giải mã là gì?

- ❑ Mật mã học là kỹ thuật bảo mật thông tin và liên lạc thông qua việc sử dụng mã để chỉ những người có mục đích sử dụng thông tin mới có thể hiểu và xử lý nó. Do đó ngăn chặn truy cập trái phép vào thông tin.
- ❑ Mật mã(cryptography)
 - Tiền tố “crypt” có nghĩa là “ẩn” và
 - hậu tố “graph” có nghĩa là “viết”.
- ❑ Mật mã bao gồm quá trình mã hóa và giải mã

Mật mã cổ điển

- ☐ Lịch sử mật mã đã hơn 3.000 năm
- ☐ Đối tượng của mật mã là các ký tự, tượng hình
- ☐ Mã hóa/Giải mã được thực hiện thủ công hoặc bằng cách sử dụng các nguyên tắc cơ học
- ☐ Áp dụng phổ biến trong quân sự: Máy Enigma gồm ba cánh quạt được quân đội Đức sử dụng trong Thế chiến thứ hai



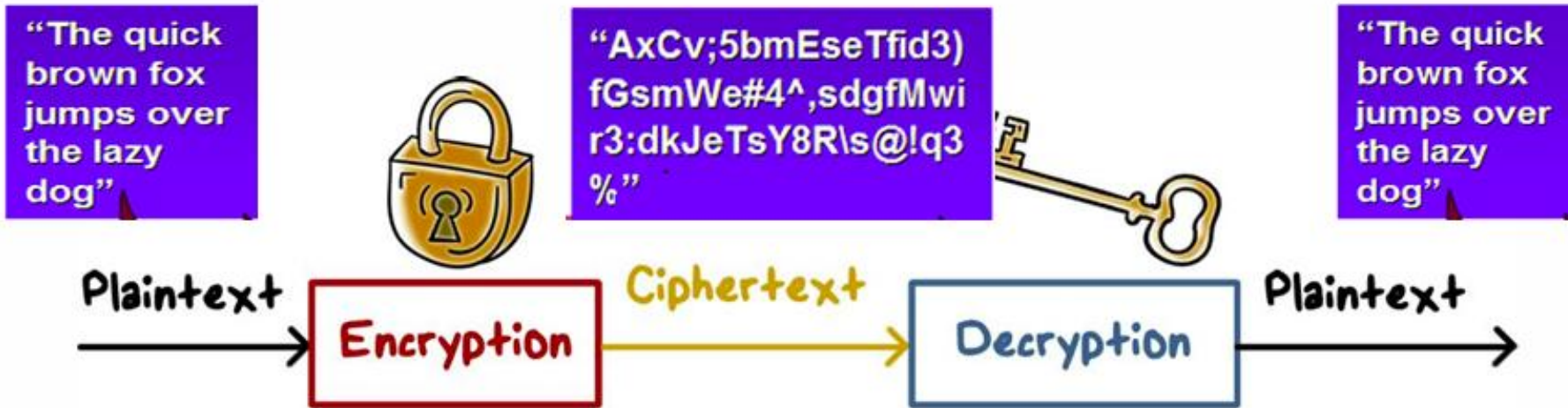
Mật mã hiện đại (từ 1970)

- ☐ Bắt đầu với sự phát triển của Máy tính và Công nghệ thông tin
- ☐ Xử lý bằng máy tính sử dụng bit
- ☐ Nhiều thuật toán mã hóa như DES, AES, RSA..
- ☐ Áp dụng rộng rãi trong nhiều lĩnh vực như xác thực, chữ ký số, trao đổi khóa, an toàn truy cập, thanh toán điện tử, an toàn giao dịch thương mại điện tử....

Các thuật ngữ chính được sử dụng trong mật mã

- ❑ **Plaintext:** Đây là thông điệp bản rõ hoặc dữ liệu ban đầu được đưa vào thuật toán mã hóa.
- ❑ **Thuật toán mã hóa:** Thực hiện nhiều hoạt động thay thế và biến đổi khác nhau trên bản rõ
- ❑ **Khóa bí mật:** là đầu vào của thuật toán mã hóa. Khóa là một giá trị độc lập với bản rõ và thuật toán.
- ❑ **Ciphertext:** Đây là thông điệp bản mã được tạo ra sau khi mã hóa. Nó phụ thuộc vào bản rõ và khóa bí mật
- ❑ **Thuật toán giải mã:** Đây thực chất là thuật toán mã hóa ngược lại. Nó lấy bản mã và khóa bí mật và tạo ra bản rõ gốc

Sơ đồ minh họa



❑ Phá vỡ một mật mã:

- Khám phá bản rõ (plaintext) từ bản mã (ciphertext), hoặc khám phá khóa
- Cố gắng khám phá khóa mã hóa để sau đó có thể giải mã tất cả dữ liệu được mã hóa bằng khóa đó.

❑ Các tấn công vào Mật mã:

- Brute-force: thử các trường hợp của khóa
- Cryptanalysis– thám mã: Phân tích thuật toán và đặc tính dữ liệu
- Side channel analysis - tấn công kênh bên: cho phép tin tặc lấy được thông tin mật mã mà không cần động đến phần bảo mật của hệ thống
- Social-engineering: sự lừa đảo để lấy khóa, bản mã gốc.



Brute-force

- thử mỗi key có thể trên 1 phần của bản mã cho đến khi một bản gốc được lấy
- Trung bình, một nửa trong số tất cả các key có thể phải thử để đạt được thành công



Cryptanalysis

- dựa vào tính chất của thuật toán và một số kiến thức về các đặc điểm chung của các bản rõ
- khai thác các đặc điểm của thuật toán để cố gắng để suy luận một text cụ thể hoặc để suy ra các key được sử dụng

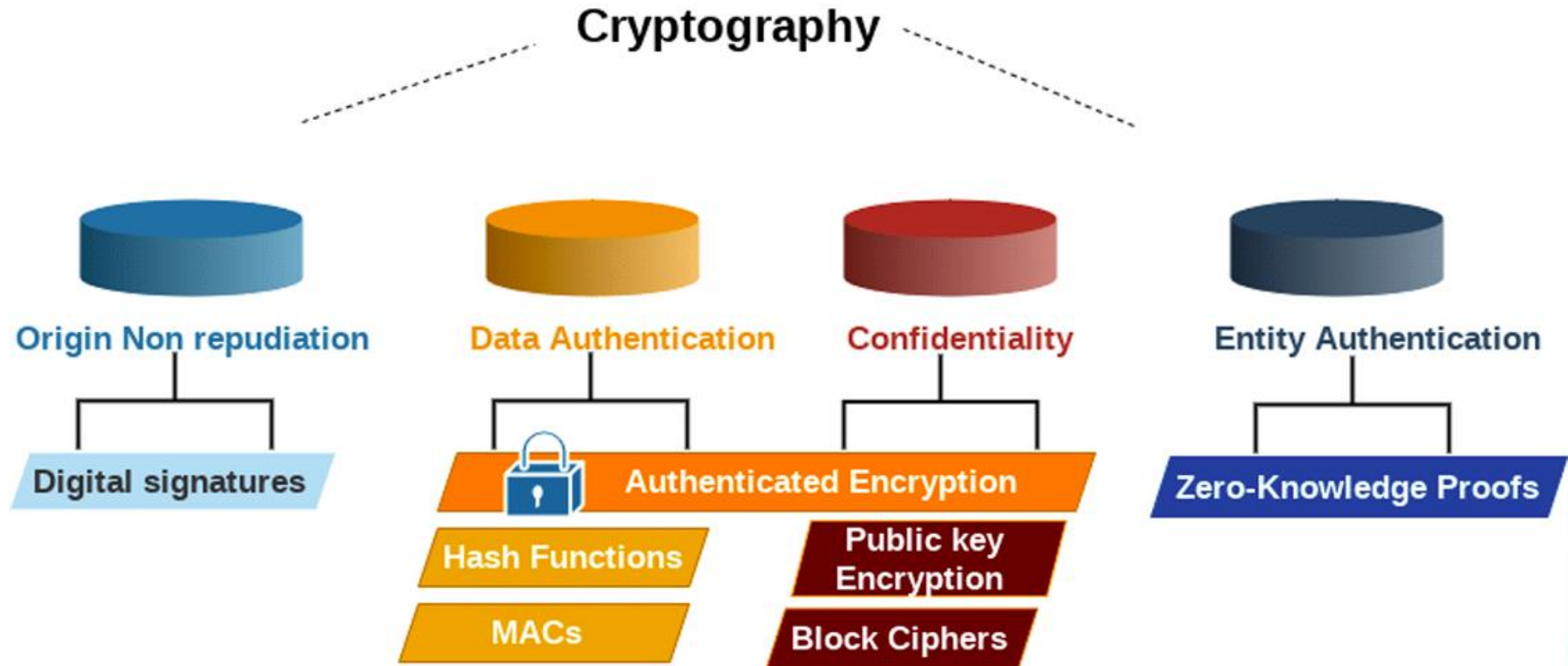
□ Một thuật toán mạnh đáp ứng 1 hoặc 2 tiêu chí sau:

- Chi phí để phá mật mã vượt quá giá trị của thông tin được mã hóa.
- Thời gian cần thiết để phá mật mã vượt quá thời gian tồn tại hữu ích của thông tin.

□ Ví dụ: Thời gian trung bình cần thiết để tìm kiếm khóa toàn diện

Key Size (bits)	Number of Alternative Keys	Time Required at 1 Decryption/ μ s	Time Required at 10^6 Decryptions/ μ s
32	$2^{32} = 4.3 \times 10^9$	$2^{31}\mu\text{s} = 35.8 \text{ minutes}$	2.15 milliseconds
56	$2^{56} = 7.2 \times 10^{16}$	$2^{55}\mu\text{s} = 1142 \text{ years}$	10.01 hours
128	$2^{128} = 3.4 \times 10^{38}$	$2^{127}\mu\text{s} = 5.4 \times 10^{24} \text{ years}$	$5.4 \times 10^{18} \text{ years}$
168	$2^{168} = 3.7 \times 10^{50}$	$2^{167}\mu\text{s} = 5.9 \times 10^{36} \text{ years}$	$5.9 \times 10^{30} \text{ years}$
26 characters (permutation)	$26! = 4 \times 10^{26}$	$2 \times 10^{26}\mu\text{s} = 6.4 \times 10^{12} \text{ years}$	$6.4 \times 10^6 \text{ years}$

Các dịch vụ mật mã



- ❑ Nguyên thủy mật mã (cryptographic primitives) là các cơ chế/thuật toán cơ bản đã được nghiên cứu và kiểm chứng rộng rãi (ví dụ: mã khối/mã dòng, hàm băm, MAC, chữ ký số, trao đổi khóa...), dùng làm khối xây dựng cho các giao thức và hệ thống bảo mật (ví dụ: TLS, SSH).
- ❑ Nguyên thủy mật mã không phải là một hệ thống hoàn chỉnh; để đạt đồng thời các mục tiêu như bí mật và toàn vẹn/xác thực, cần kết hợp primitives theo cấu trúc đúng trong giao thức (ví dụ: dùng mã hóa có xác thực – AEAD như AES-GCM/ChaCha20-Poly1305, hoặc mô hình Encrypt-then-MAC).

Dựa vào các yếu tố khác nhau sẽ có sự phân loại khác nhau

Dựa vào kiểu thao tác tác được dùng để chuyển từ plaintext sang ciphertext

Substitution

Trasposition

Dựa vào số loại khóa được dùng

Symmetric

Asymmetric

Dựa vào cách plaintext được xử lý

Block

Stream

- ❑ Substitution– thay thế: Plaintext được thay thế bằng kí tự, số, hay kí hiệu khác
- ❑ Nếu plaintext được xem như một chuỗi các bit thì việc thay thế bao gồm việc thay thế các mẫu bit của plaintext bằng các mẫu bit của ciphertext.
- ❑ Các thuật toán Mật mã dạng thay thế cổ điển
 - Caesar Cipher,
 - Monoalphabetic Ciphers,
 - Playfair Cipher,
 - Polyalphabetic Ciphers

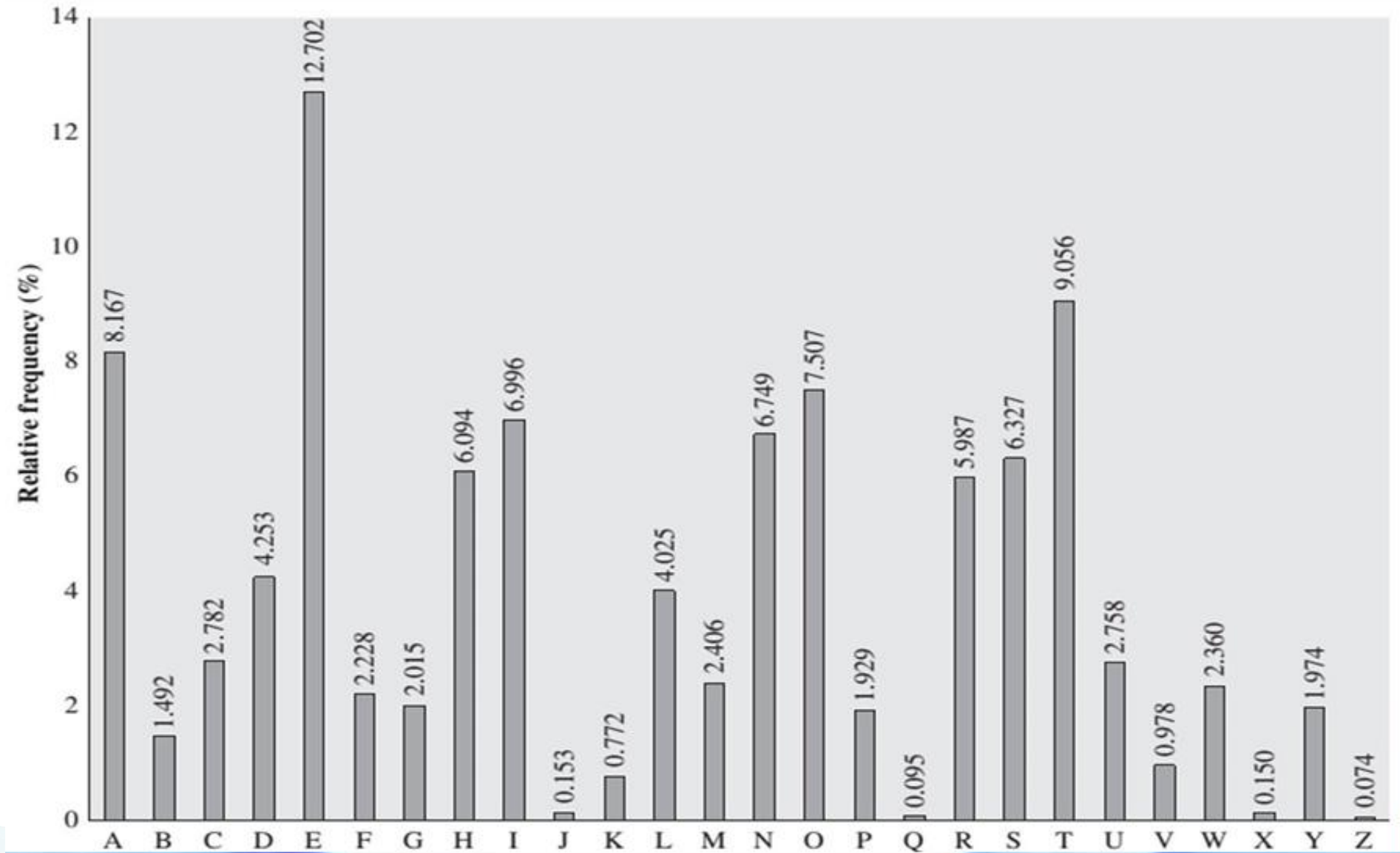
- ❑ Mật mã Caesar: được phát minh bởi Julius Caesar: sớm nhất, đơn giản nhất.
- ❑ Đối với mỗi chữ cái trong văn bản gốc p , hãy thay thế chữ cái trong văn bản mã hóa C , tham số dịch chuyển k được sử dụng làm khóa
- ❑ Thuật toán mã hóa $C = E(k, p) = (p + k) \bmod 26$ trong đó k nhận giá trị trong khoảng từ 1 đến 25.
- ❑ Thuật toán giải mã $p = D(k, C) = (C - k) \bmod 26$
- ❑ Caesar dễ dàng bị tấn công Brute-Force, chỉ thử 25 lần
- ❑ Các thuật toán mã hóa và giải mã đã được biết

Ví dụ: $P = \text{hello}$, $k=2 \Rightarrow C = \text{jgnnq}$

$C = \text{LQIRUPDWLRQVHFXULWB}$. No key. $P=?$

- ❑ Monoalphabetic- đơn bảng: tổng quát hóa của Ceasar
 - Không phải là một dịch chuyển k vị trí của các chữ cái A, B, C, ...
 - Mà là một hoán vị của 26 chữ cái này, mỗi hoán vị được xem như là một khóa.
- ❑ Việc mã hóa được tiến hành bằng cách thay thế một chữ cái trong bản rõ thành một chữ cái trong bản mã.
 - Việc ánh xạ được thực hiện ngẫu nhiên và sự khác biệt giữa các chữ cái không đồng nhất.
 - 1 bảng chữ cái mật mã duy nhất được sử dụng cho mỗi mess. ($d \Rightarrow e$; or $g \Rightarrow e$, tùy mess)
 - Số lượng hoán vị của 26 chữ cái là $26! = 4 \times 10^{26}$ (tương đương với số khóa).
 - $\Rightarrow$ tấn công Brute-Force khó – tốn time.
- ❑ Phương pháp này được xem là an toàn trong suốt 1000 năm sau công nguyên.

- ❑ Phá mã Monoalphabetic: do Al-Kindi (Ả Rập, thế kỷ 9) đã phát hiện ra một phương pháp phá mã dựa vào tần suất sử dụng của các chữ cái. Có thể suy ra các cặp chữ cái nguyên bản - chữ cái bản mã
- ❑ Ví dụ : chữ cái xuất hiện nhiều nhất có thể tương ứng với 'e'
- ❑ Có thể nhận ra các bộ đôi và bộ ba chữ cái:
 - Ví dụ bộ đôi : 'th', 'an', 'ed';
 - Ví dụ bộ ba : 'ing', 'the', 'est'



Ví dụ: Cần thống kê tần số sử dụng của các đơn/ đôi/ ba chữ cái của bản mã, sau đó thay thế

```

UZQSOVUOHXMOPVGPOZPEVSGZWSZOPFPESXUDBMETSXAIZ
t a      e e te a that e e a      a
VUEPHZHMDZSHZOWSFPAPPDTSVPQUZWYMXUZUHSX
e t  ta t ha e ee a e th  t a
EPYEPOPDZSZUFPOMBZWPFUPZHMDJUDTMOHMQ
e e e tat e  the t

```

Paintext:

it was disclosed yesterday that several informal but
direct contacts have been made with political
representatives of the viet cong in moscow

- ☐ Được phát minh bởi nhà khoa học người Anh Sir Charles Wheatstone vào năm 1854 (tên bạn ông - Baron Playfair)
- ☐ Mật mã mã hóa nhiều chữ cái nổi tiếng nhất
- ☐ Xử lý các sơ đồ trong bản rõ dưới dạng các đơn vị đơn lẻ và chuyển các đơn vị này thành các sơ đồ bản mã
- ☐ Ví dụ: yêu về => dg tu
- ☐ Dựa trên việc sử dụng ma trận 5 x 5 các chữ cái được xây dựng bằng từ khóa
- ☐ Được sử dụng làm hệ thống mã chiến tiêu chuẩn của Quân đội Anh trong Thế chiến thứ nhất và Quân đội Hoa Kỳ và các lực lượng Đồng minh khác trong Thế chiến thứ hai

❑ Lập ma trận 5x5: (I & J: cùng một ô)

- Điền các chữ cái của khóa từ trái qua phải và từ trên xuống dưới, không trùng nhau
- Điền phần còn lại của ma trận bằng các chữ cái còn lại theo thứ tự bảng chữ cái

❑ Xử lý plaintext: Bản rõ được mã hóa hai chữ cái cùng một lúc,

- Tách plaintext từng cặp (2) chữ cái, nếu một cặp là 2 chữ cái giống nhau thì chèn đệm 'X',
- ví dụ: balloon-> ba lx lo on

❑ Mã hóa theo quy tắc: lấy từng cặp chữ cái trong plaintext

- Nếu cả 2 nằm trong cùng hàng, thì thay thế từng chữ cái bằng chữ cái bên phải
- Nếu cả 2 nằm trong cùng cột, thì thay thế mỗi chữ cái bằng chữ cái bên dưới nó
- Còn lại, mỗi chữ cái sẽ được thay thế bằng chữ cái trong cùng hàng và trong cột của chữ cái còn lại trong cặp

□ Plaintext: Hellos => he lx lo sx

□ Key: MONARCHY.

□ Mã hóa:

- he lx lo sx=> cf su pm xa

M	O	N	A	R
C	H	Y	B	D
E	F	G	I/J	K
L	P	Q	S	T
U	V	W	X	Z

❑ Lập ma trận 5x5

❑ Giải mã theo quy tắc: lấy từng cặp chữ cái trong ciphertext

- Nếu cả 2 nằm trong cùng hàng, thì thay thế từng chữ cái bằng chữ cái bên trái
- Nếu cả 2 nằm trong cùng cột, thì thay thế mỗi chữ cái bằng chữ cái bên trên nó
- Nếu 2 chữ cái giống nhau (tức cùng cột, cùng dòng), thay thế bằng các ký tự ở bên trái và phía trên.
- Ngược lại, mỗi chữ cái sẽ được thay thế bằng chữ cái trong cùng hàng và trong cột của chữ cái còn lại trong cặp

❑ Ví dụ: EC -> HA, BC -> AB, RU -> GR, XX->SS

*	*	*	*	*
*	A	B	C	D
*	E	G	H	P
*	*	R	S	*
*	T	U	X	Z

- ☐ Bảo mật được cải thiện nhiều so với bảng chữ cái đơn
- ☐ Vì có $26 \times 26 = 676$ digram
- ☐ Sẽ cần bảng tần số nhập 676 để phân tích (so với 26 đối với bảng chữ cái đơn)
- ☐ Tương ứng, nhiều bản mã hơn đã được sử dụng rộng rãi trong nhiều năm, vd. của quân đội Mỹ và Anh trong Thế chiến thứ nhất
- ☐ Bản mã vẫn còn lưu lại nhiều cấu trúc của nguyên bản
- ☐ Vẫn có thể phá mã được vì chỉ có vài trăm cặp chữ cái cần giải mã

❑ Vigenère: do Vigenere (Pháp, thế kỷ 15) tìm ra

- Là một hệ mã hóa thay thế đa bảng (polyalphabetic)
- Trong sơ đồ này, tập hợp các quy tắc thay thế dùng một bảng chữ cái có liên quan bao gồm 26 mật mã Caesar có độ dịch chuyển từ 0 đến 25.

❑ Mã hóa: từng cặp ký tự trong khóa & plaintext

- Xử lý khóa: khóa được lặp đi lặp lại để chiều dài bằng chiều dài của plaintext
- Bảng được cho: gồm cột dọc (A-Z) để tra key, cột ngang (A-Z) tra plaintext
- Tra bảng: từng cặp ký tự trong khóa & plaintext
- Lấy giao giữa ký tự tương ứng cột chứa khóa và plaintext chính là ký tự của ciphertext.

	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
A	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
B	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A
C	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B
D	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C
E	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D
F	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E
G	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F
H	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G
I	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H
J	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I
K	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J
L	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K
M	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L
N	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M
O	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N
P	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O
Q	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P
R	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q
S	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R
T	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S
U	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T
V	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U
W	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V
X	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W
Y	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X
Z	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y

Key

plaintext

- ❑ the key: deceptive,
- ❑ the plaintext: we are discovered save yourself
- ❑ key: d e c e p t i v e d e c e p t i v e d e c e p t i v e
- ❑ plaintext: w e a r e d i s c o v e r e d s a v e y o u r s e l f
- ❑ ciphertext: Z I C V T W Q N G R Z G V T W A V Z H C Q Y G L M G J
- ❑ Tra bảng Vigenère:
 - Row d + column w -> Z
 - Row e + column e -> I

- ❑ Ta định vị chữ cái đầu tiên của khóa ở cột bên trái và định vị chữ cái đầu tiên của thông điệp được mã hóa bên trong bảng, sau đó dóng thẳng lên hàng tiêu đề để lấy được chữ đầu tiên của plaintext.
- ❑ Tiếp tục với các chữ cái tiếp theo của thông điệp được mã hóa và các chữ cái tiếp theo của khóa, khi đến chữ cái cuối khóa thì quay lại chữ cái đầu tiên của khóa.
- ❑ Ví dụ: K= KEY. C= NGMNI.
 - Xác định vị trí chữ cái K trên cột đầu tiên và trên hàng của cột đó, hãy tìm ô có chữ cái N, tên cột của nó là D, đây là chữ cái đầu tiên của thông báo đơn giản tiếp tục
 - Plaintext là DCODE

Transposition– dịch chuyển: Thực hiện một số hoán vị trên các chữ cái trong plaintext.

Có các thuật toán:

□ Rail fence: đơn giản

- Ghi các ký tự trong bản rõ theo từng hàng rào, sau đó kết xuất bản mã dựa trên cột.

Sau đó đọc bản mã theo từng hàng

- Ví dụ: plaintext: meet me after the toga party, k=2. Ta viết như sau:

m e m a t r h t g p r y

e t e f e t e o a a t

- ciphertext: MEMATRHTGPRYETEFETEOAAT

□ Transposition– dạng phức tạp hơn

- Plaintext: viết từng chữ vào trong một bảng, từng hàng
- Key là một dãy số
- Ciphertext: đọc từng cột ra theo thứ tự cột tương ứng với số từ nhỏ đến lớn trong dãy số key

Ví dụ:

- key
- Plaintext
- Ciphertext: TTNAAPTMTSUOAODWCOIXKNLYPETZ

4	3	1	2	5	6	7
a	t	t	a	c	k	p
o	s	t	p	o	n	e
d	u	n	t	i	l	t
w	o	a	m	x	y	z

Dựa vào số loại khóa
được dùng

Symmetric

Asymmetric

- Mật mã đối xứng là hệ thống Mật mã sử dụng một khóa bí mật chia sẻ (shared-secret-key) cho cả hai quá trình mã hóa và giải mã.
 - Ví dụ: DES, 3DES, AES
- Mật mã bất đối xứng là hệ thống Mật mã sử dụng một khóa công khai (public key) và một khóa bí mật (private key) cho quá trình mã hóa và giải mã, RSA

Chi tiết ở chương 8,9

❑ Hash (hàm băm): ánh xạ thông điệp có độ dài thay đổi thành giá trị băm có độ dài cố định:

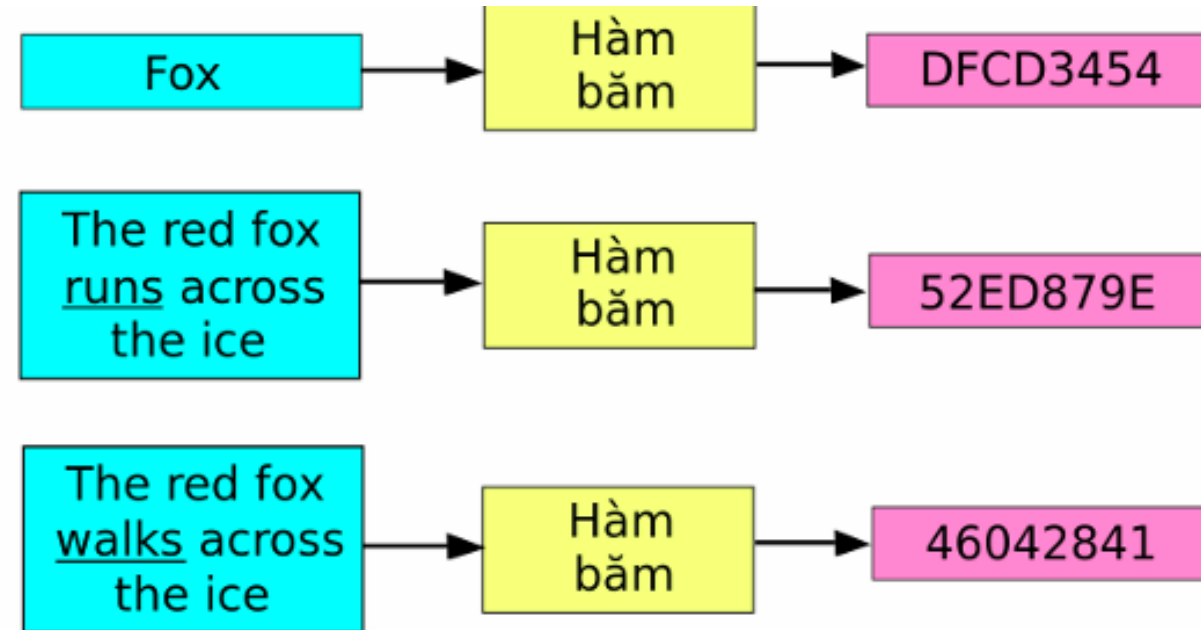
$$h = H(M)$$

❑ sử dụng cho nhiều mục đích khác nhau

- Mã hóa (cryptography),
- Nén (compression),
- Tạo tổng kiểm tra (checksum generation)
- Lập chỉ mục dữ liệu (data indexing)

❑ Trong an toàn thông tin: Hash ứng dụng:

- Kiểm tra tính toàn vẹn dữ liệu
- Bảo mật mật khẩu
- Xác thực dữ liệu



❑ Chữ ký số:

- Cho phép người tạo thông điệp đính kèm mã đóng vai trò là chữ ký.
- Được hình thành bằng cách lấy hàm băm của thông điệp và mã hóa thông điệp bằng khóa riêng của người tạo.

❑ Thuộc tính chữ ký số:

- Xác minh tác giả và thời gian ký.
- Xác thực nội dung tại thời điểm ký.
- Nó phải được bên thứ ba xác minh để giải quyết tranh chấp

- ☐ Mật mã: khái niệm, hoạt động
- ☐ Các kỹ thuật Mật mã: Substitution và Transposition
- ☐ Các dạng Mật mã: Symmetric và asymmetric encryption
- ☐ Mã hóa Hash
- ☐ Digital signatures



AN TOÀN THÔNG TIN (INSE330380)

Kết thúc chương 7

Ths. ĐỖ MINH HẬU



Trung tâm Học liệu và Dạy học số
Đại học Công nghệ Kỹ thuật Tp. Hồ Chí Minh
01 Võ Văn Ngân, P. Thủ Đức, Tp. Hồ Chí Minh
daotaotuxa@hcmute.edu.vn